

Cyber Security 1: Exam Two

The exam started at 16:01.

Answer by selecting one option in each question. After intermediate saving, you will see your selection. You can make any number of savings. At least one must be done before final saving becomes possible. Do not navigate except through buttons or this link: ([General instructions on its own tab.](#))

In the real and practice exams you can also express uncertainty of your answer to halve the eventual plus or minus points, and tell – for research purposes – whether you remember the question, without effect to points.

1. If a data-processing device is to be able to operate in a hostile environment, the most important data to be protected - if present -

- ☐ are cryptographic keys.
- ☐ are web addresses.
- ☐ is configuration information.
- ☐ are access control lists.

2. Destroying a file with multiple overwrites does not necessarily guarantee that the information contained in the file could not yet be obtained by unauthorized persons. If a leak occurs, which of the following is the most *likely* cause?

- ☐ The overwrite program does not reach all the file storage blocks on the disk due to a malfunction of the file manager.
- ☐ Even when overwritten, the magnetic field used to store the original data is exposed by special devices.
- ☐ An attacker has inserted a Trojan horse to the overwrite program that copies and sends the data before its normal operation.
- ☐ An attacker first obtains a file name from an archived list and then manages to find a copy of the file on some other storage medium.

3. An internet troll is a type of

- ☐ author of disturbing messages.
- ☐ hacker who is trying to find and sell vulnerabilities to anyone who wants to pay.
- ☐ anonymous communication protocol.
- ☐ fake news that is spreading unusually fast.

4. Device drivers that are installed by the end-user must be designed securely, because they usually

- ☐ have the same access rights as the end-user.
- ☐ become integrated as part of the operating system.
- ☐ are configured by software without human interaction.
- ☐ operate in the unrestricted, or kernel, mode.

5. Which of the following is not part of key management in a symmetric cryptosystem ?

- ☐ controlling the purpose of the key usage
- ☐ setting the key to a revocation list
- ☐ backing up / restoring the key
- ☐ forced escrow of the key

Intermediate save

6. A bastion host is

- ☐ a hardened single-purpose server at the outer edge of the organization's network.
 - ☐ a workstation that has no services installed for remote use except possibly the administrative connection.
 - ☐ a computer that has only an outbound connection to the internet.
 - ☐ another name for the edge router of an organization network in case it has been equipped with DoS protection.
-

7. For mandatory access control to work the data owner must determine

- ☐ a sufficient level of consensus among users.
 - ☐ the users' need to know.
 - ☐ the method of verifying users' identities.
 - ☐ the method of validating users' authorization.
-

8. The message authentication code, MAC, is computed

- ☐ by applying asymmetric encryption to the message.
 - ☐ by applying a keyed hash function to the message.
 - ☐ by applying a hash function to a random challenge.
 - ☐ by applying symmetric encryption to a random challenge.
-

9. What does accountability mean in the field of information security?

- ☐ The user's actions are logged and in case of security incidences it will be known whether the user is responsible or not.
 - ☐ The users or their departments have to pay the costs of resolving security incidents caused by the users.
 - ☐ The users or their departments have to pay for the CPU and network usage, and logs are kept to enable this.
 - ☐ The user's actions in the information system are recorded in log files and they are used for evaluation of the user with respect to rewards or sanctions.
-

10. What is injected in an injection attack?

- ☐ Fake users and their profiles into a user database.
 - ☐ Malicious plug-ins into web browsers without the user being notified.
 - ☐ Program code to places that allow non-executable input but end up by running the code.
 - ☐ One or more digits to monetary values, or just new digits to some existing positions in numbers.
-

11. Consider the claim: "Even an IT work environment produces dust that, when accumulated, can cause short circuits in computing devices." The claim is

- ☐ false because the hardware fans are built to prevent dust from accumulating in the wrong places.
- ☐ true because the static electricity of IT equipment collects dust specifically in the wrong places.
- ☐ true because there are people in the work environment and therefore dust that conducts electricity.
- ☐ false because dust in a normal work environment does not conduct electricity.

Intermediate save

12. In an organization security awareness training should include

- ☐ the high-level outcome of vulnerability assessments.
 - ☐ security objectives that the organization has a legal obligation to comply with.
 - ☐ specialized curriculum assignments, coursework and an accredited training institution.
 - ☐ security roles and responsibilities for staff.
-

13. Obfuscation means the methods

- ☐ that malware writers use to make their code versions to look different, to evade detection.
 - ☐ by which a sandbox is created around untrusted software.
 - ☐ that malware writers use to cause their code to modify itself in the course of replications, to evade detection.
 - ☐ that code writers use while attempting to make reverse engineering more difficult.
-

14. In an organization both disaster recovery and business continuity need a plan, and when information security is concerned the term disaster recovery commonly refers to the recovery of

- ☐ personnel environments.
 - ☐ organization operations.
 - ☐ manufacturing environment.
 - ☐ technology environment.
-

15. A web bug is

- ☐ mobile code that is roaming web sites to gather their update status.
 - ☐ an invisible element on a web page, revealing user's presence on that page to its home site.
 - ☐ a vulnerability in the server-side code of a web site.
 - ☐ a programming error in the client-side code of a web page.
-

16. Organization impact analysis

- ☐ calculates the probability of disruptions to the organization.
 - ☐ is critical to development of a business continuity plan.
 - ☐ is just a different term to describe risk analysis.
 - ☐ establishes the effect of disruptions on the organization.
-

17. What is a property of the Diffie-Hellman key exchange protocol?

- ☐ One party invents a prime p and the other a prime q . The product n of these large numbers is the public key that acts as the key exchange modulus.
- ☐ In order to include authentication, the parties must first secretly agree on the modulus p and the base g .
- ☐ If calculating discrete logarithms modulo a large prime number is indeed a difficult problem (as is generally believed), the DH protocol provides the protocol participants with the same key that no one else knows.
- ☐ Both parties raise the base g to a power modulo p , and the result is communicated to the other, but neither one will come to know what the exponent used by the other party was.

Intermediate save

18. All of the following have something to do with redundancy. What has the least to do with the sort of redundancy that is used to protect integrity?

- ☐ metadata, i.e. data about data
 - ☐ backup
 - ☐ hash function computed from data
 - ☐ entropy
-

19. Assume that one employee of a company needs to access files and programs on a mainframe computer from his home computer. Which of the following is a better design for this than the others?

- ☐ Authentication and encryption between endpoints.
- ☐ A network that has been made private with virtualization.
- ☐ Implementing work via a TLS-secured web server instead of a terminal connection.
- ☐ Current-day PC's are powerful enough. So, set up programs and files on the employee's home computer locally.

20. An operating system together with the underlying hardware can provide a controlled and un-intercepted interface into privileged user functions by

- ☐ trusted paths.
- ☐ ring protection.
- ☐ anti-malware.
- ☐ maintenance hooks.

21. What is the worst problem with biometric authentication that should work over an insecure network like the internet?

- ☐ The proportion of erroneous approvals cannot be reduced by renewals.
- ☐ The integrity or encryption of data can be broken during transmission through the network.
- ☐ Someone can get hold of the comparison data on the server.
- ☐ It is not known whether the input of the authentication data is made by the same person as the one to which it belongs.

22. ARP poisoning

- ☐ happens when malware corrupts the program that runs the Address Resolution Protocol.
- ☐ is a result from an attacker randomly changing several MAC addresses of devices in a local network.
- ☐ is a result of an attacker sending fake ARP messages within a LAN.
- ☐ halts the operation of a LAN because the addresses in the ARP table point to non-existent MACs.

23. Some features of downloaded software can be verified by signatures provided by Verisign, for example, but these only guarantee that the

- ☐ code passed a virus scan, albeit by several different methods.
- ☐ software corresponds to its specifications.
- ☐ code manufacturer takes responsibility for any security issues.
- ☐ code origin and integrity are correct.

Intermediate save

24. Which of the following applies to 4G and 5G mobile phone systems? Here "the phone is authenticated" means that its SIM / USIM is authenticated.

- ☐ In both, the phone is authenticated to the phone network.
- ☐ In 5G, the phone network is authenticated to the phone, but not in 4G.
- ☐ The phone is authenticated to the phone network in 5G, but not in 4G.
- ☐ The phone is authenticated in 5G to the receiving 5G phone, but the same does not happen in 4G.

25. In your new IoT gadget, i.e. in the appliance that joins the Internet of Things, what is the most likely weakness with respect to information security?

- ☐ The connection to a server network that collects not only statistics but personal usage data.
- ☐ Default password that you didn't change.
- ☐ Unfiltered power cord that allows easy side channel attacks.
- ☐ A spy module set up by the importer based on regulations of the Finnish authorities.

26. Which of the following would be the most stringent requirement when a wide variety of summary information can be retrieved from a database of persons, but a field is sensitive at the individual level? "The search results must not reveal even

- ☐ a rough range in which the value of that field is for a particular person."
- ☐ whether the value of that field for a particular person is different from what is given in the search criteria."
- ☐ the average of that field if less than half of the records in the database are included in its calculation."
- ☐ a list of those who have an entry at all in that field."

27. Two complementary viewpoints in information security are: (i) people can be protected from information or (ii) information from people. Which among the following is the most common example of (i)?

- ☐ Information may become harmfully unreliable if modified by too many.
- ☐ Big web shops like Amazon have effective recommendation mechanisms that filter out most uninteresting items.
- ☐ Information that is freely available elsewhere is not wanted somewhere in the world.
- ☐ Unsolicited bulk email is effectively filtered at several stages between the senders and receivers.

28. You receive an email with an attachment from a person that you know. The email is digitally signed but your email client cannot verify the signature. What is the best course of action?

- ☐ Forward the email to another address with a new signature.
- ☐ Delete the email.
- ☐ Open the attachment to determine if the signature is valid.
- ☐ Determine why the signature cannot be verified before opening the attachment.

29. Prior to a software update in production systems, it is most important that

- ☐ the patching process is documented.
- ☐ the production systems are backed up.
- ☐ an independent third party attests the validity of the patch.
- ☐ full information is available about the threat that the patch addresses .

Intermediate save

30. What is replayed in a replay attack, at least in such cases that have been successful?

- ☐ Earlier messages of an authentication protocol in an attempt to get authenticated without proper credentials.
- ☐ An earlier successfully broken DRM signal in an attempt to get access to new media content.
- ☐ A few seconds old GPS signal toward the receivers of military vehicle or aircraft.
- ☐ The content of earlier video in the monitors of a surveillance room.

31. Which of the following 64-bit strings is more likely to be generated by random.org, whose bits are very genuinely random? Strictly speaking, they are all equally probable, but judge on the basis of ordinary statistical properties that are used to evaluate generators of pseudorandomness.

- ☐ 10001111 00011111 10110001 11101100 00011110 11011000 11110001 10111100
- ☐ 00001101 00000101 01000100 01000010 01101010 10011000 00001010 01010100
- ☐ 11001000 11010101 01010101 01011011 01101101 10110110 01100110 01100110
- ☐ 00001101 00000101 01000100 01011001 11101110 01011000 10001011 11111111

32. None of the following is a definition of a buffer overflow, but which one best *describes* it?

- ☐ It is always a security threat because an attacker can use it to cause evil - at least a program crash.
- ☐ The program counter, i.e. the address of the next instruction to be executed, is moved forward by one, even if it is already in the last instruction of the subroutine.
- ☐ A number larger than the array size is used to index the array, and the operating system does not block this reference.
- ☐ A memory reference made by a program points to another process's memory area.

33. Cryptographic algorithms have an information-theoretical goal called confusion. How does that manifest itself in practice?

- ☐ It scatters plaintext distributions into the entire ciphertext using permutations.
- ☐ It compresses the ciphertext into a shorter bit string than the original plaintext was.
- ☐ It blurs the relation between cleartext and ciphertext by making substitutions.
- ☐ It obscures the connection between clear and ciphertext by adding extra so-called "salt bits" to the ciphertext.

34. Suppose that a certain group structure for subjects and objects has already been created for access control: all entities belong to one or more groups. Which of the following models allows the most access? Subject is allowed to access an object if the

- ☐ groups of the object is a subset of the groups of the subject.
- ☐ subject belongs to at least one of the groups of the object.
- ☐ groups of the subject is a subset of the groups of the object.
- ☐ subject belongs to exactly the same groups as the object.

35. What can be considered a basic model of work in information security?

- ☐ Repeated identification of asset values and threats to them, and mitigation of risks in order of priority.
- ☐ Optimization to find the most economical alternative between good but expensive security measures and losses due to not using them.
- ☐ Confidentiality, integrity and availability.
- ☐ Division to the phases of prevention, detection and response.

Intermediate save

36. How do smart cards relate to symmetric key cryptography? Their processors

- ☐ are usually not versatile enough for that.
- ☐ are capable of it, but data transfer is impractically slow for a large amount of data to be encrypted.
- ☐ are usually not fast enough to think of sensible use for encryption.
- ☐ are capable of it, but cannot stand encrypting large amounts of data without becoming too hot.

37. Meet-in-the-middle is an attack type where

- ☐ the attacker or his process relays modified messages between two unknowing communication parties.
- ☐ password hashes are broken by optimizing the use of rainbow tables.
- ☐ the statistics of the birthday paradox are simultaneously applied to identity theft of many individuals.
- ☐ a cryptographic algorithm is broken at about a square root of effort by working both from the start and end toward the middle.

38. Assume that two processes compete for a shared resource. If they cooperate in such a way that the system's security policy is violated, the situation is called

- ☐ a race condition.
- ☐ denial of service.
- ☐ a covert channel.
- ☐ object reuse.

39. Consider an ongoing and important task with information systems that does not require special training. If only one person is in charge of this task and the organization is not at all prepared to the situation where he or she falls sick, the operation of the organization may be severely disrupted. What is the most cost-effective way of getting prepared?

- ☐ Accurately document the task and ensure that the person in question keeps the documentation up to date and available.
 - ☐ Divide the work for two or more permanent workers who perform other tasks part-time.
 - ☐ Recycle tasks from time to time, allowing employees to accumulate skills for multiple tasks.
 - ☐ Introduce a few other employees as deputies and maintain their expertise.
-

40. What kinds of payment systems are the Finnish Siirto, Swedish Swish and Danish MobilePay?

- ☐ localized versions of an American system
 - ☐ credit based
 - ☐ insecure unless used within a VPN connection to one's own bank.
 - ☐ working without the payer knowing the payee's account number
-

41. The domain name system, DNS,

- ☐ is constantly under DoS and spoofing attacks which cause the majority of downtime for internet users.
- ☐ has the security extension DNSSEC, but even that does not provide confidentiality to the DNS queries.
- ☐ is necessary for the operation of the web.
- ☐ has the shortcoming that it cannot be implemented within a single organization for internal use.

Intermediate save

42. A job announcement for professor in Cyber security (Oulu 2020) outlines the research field in this way: "Traditional thinking in system development may have considered trust as an afterthought: Opposite thinking would be to focus data collection, keeping data and its processing ____, simplifying and securing each step in processing and expiring collected data as swiftly as possible." What belongs to the slot?

- ☐ local
 - ☐ distributed
 - ☐ encrypted
 - ☐ public
-

43. By applying her private key, the key holder can establish a connection between the corresponding public key K and her own identity. This connection

- ☐ allows others to trust claims about who holds K.
 - ☐ may have the advantage that others know that the originator of the connection knows the private key corresponding to K.
 - ☐ is the basis for others to gain trust in who holds the private key corresponding to K.
 - ☐ is necessary to indicate who is in possession of that private key.
-

44. Which of the following statements is true?

- ☐ Testing does not help in making software under construction completely secure because some vulnerabilities do not appear in any kind of testing.
 - ☐ Good programming methods, testing, and proving have very little effect on the security of complex software.
 - ☐ Secure programs can be proven to be such using formal verification methods.
 - ☐ Testing does not make software under construction completely secure because it is virtually impossible to go through all the options.
-

45. One possible action of IPsec is that it

- ☐ compresses the data packet.
- ☐ sends the decryption key with the data packet in a digital envelope.

- ☐ adds a field to the data packet with a keyed hash computed from the packet.
- ☐ outputs an outgoing data packet with all IP addresses encrypted.

46. Advanced persistent threat refers to

- ☐ a zero-day vulnerability, which the finder has sold to some party other than the manufacturer or vendor who is responsible for patching it.
- ☐ a threat actor with plentiful resources who has gained unauthorized access to an information system and stays undetected for an extended period of time.
- ☐ a Trojan horse that applies some novel method to compromise the system where it is residing.
- ☐ a vulnerability that has not been patched.

47. The purpose of the operating system is NOT to combat the integrity problem that threatens the database in the situation, where

- ☐ the data transfer gets out of sync between the main memory of the database machine and the peripheral memory.
- ☐ two users updating the database read the same information from the database at the same time.
- ☐ a user level process of a hacker attempting to write to the memory area used by the database manager.
- ☐ simultaneous users start the database management program in two or more separate processes.

Intermediate save

48. Most symmetric ciphers are length-preserving. Sometimes it is motivated in the course of encryption to produce a longer result than the plaintext. Which is the **poorest** motivation for this?

- ☐ Sending the initialisation vector of CBC mode along with the cryptotext.
- ☐ Including a recognizable header to the plaintext to allow checking that the decryption key was correct.
- ☐ Including in the message the symmetric key in a public-key-encrypted "envelope".
- ☐ Including a separately computed MAC to the cryptotext.

49. Which of the following is least important when the design of data network structures follows restrictions and limits as a general security principle?

- ☐ Placing the server collecting logs on its own subnet.
- ☐ Keeping administrative and production data channels separate.
- ☐ Placing web and database servers on different subnets.
- ☐ Placing a DNS and NTP server on different subnets.

50. Investigate the claim: "The certificate sent by a server can be installed in the browser so that TLS can use it to verify the private key of the same server in the future." The claim is

- ☐ false, because you can install public keys but not certificates in your browser.
- ☐ false, as TLS does not verify the server's private key but the signature made with that private key.
- ☐ true, but the browser needs to be shut down and restarted.
- ☐ true and does not require a browser restart.

51. The idea of classifying data is to

- ☐ structure the data so that it is easier to make automatic decisions about the requirements for access control and other processing.
 - ☐ express concisely the requirements for access control and other processing of the files.
 - ☐ mark materials in terms of confidentiality, freshness, integrity and availability.
 - ☐ structure information so that it is easier for people to make decisions about how to handle its content.
-

52. What is the '3-2-1' rule for backups?

- ☐ At least 3 copies, on 2 devices, and 1 offsite.
- ☐ At least 3 generations, 2 copies of each, and 1 offline.
- ☐ At least 3 generations, 2 copies of each, and a new copy once per day.
- ☐ At least 3 copies, on 2 sites, and 1 offline.

Intermediate save

Make at least one intermediate saving. After that the ending button for this stage appears here.